

5. Risk impact, i.e. severity of occurred threat, is evaluated. Criteria used to evaluate the impact are: level of lost confidentiality, integrity, and availability of information. The levels are described later in this section in more detail.
6. The total magnitude of risk is achieved by combining the impact and probability.

Probability estimation is often the most challenging part of risk assessment. It is particularly true for IT security risks where historical data on previous occurred risks are either not available or not relevant. Most IT security risks are possible future events that have not yet occurred⁶ in the current IT environment, and as such, their probability cannot be measured but only estimated. The process is undermined when probability estimation appears to be a subjective opinion. Thus, in order to ensure the credibility and value of the IT security risk management process, data shall be collected from the following information sources and assessed with care:

- ECHA's specific data of occurred threats/risks and security events, where risks have not occurred but realization has been very close, e.g. intrusion attempts to ECHA internal network
- Non-public data from other organization through existing professional networks and other relationships (e.g. CERT-EU, CERT-FI)
- Public data, especially if there is any statistics of occurred threat or risk

Also, subjective view as an inaccuracy factor is reduced by discussing with other experts, and taking into account their view.

While the probability of risk occurrence cannot be *measured*, but only *estimated*, the risk probability is mapped to a pre-defined category instead of trying to find exact numeric value. In ECHA's risk management model there are the following categories defined:

- Frequent – Expected to occur often or at least several times in the service/system lifetime; occurs frequently
- Occasional – Occurs few times in service/system lifetime. Expected to occur at least twice in service/system life time; occurs periodically.
- Seldom - Possible to occur in service/system lifetime. Expected to occur once in service/system life; occurs rarely.
- Unlikely - not assumed to occur in service/system lifetime. Possible, but improbable; occurs only very rarely.

Risk impact, i.e. severity of occurred threat, is evaluated using the level of loss of confidentiality, integrity, and availability as criteria. The matrix below defines levels of confidentiality, integrity, and availability with a high level guidance as to how those levels should be applied.

IMPACT OF LOSS		
LOW	MODERATE	HIGH

⁶ The risk might have occurred once or couple of times but there is no enough data for statistical assessment